

Marco integrativo GQM + PRAGMATIC para métricas de Agentic IA

1. Propósito del marco

Este marco integra la metodología **Goal-Question-Metric (GQM)** con la metamétrica **PRAGMATIC** para asegurar que cada indicador de Agentic IA conecta con objetivos nacionales, preguntas de gestión y datos técnicos, y que además cada métrica se evalúa por su utilidad real (predictiva, relevante, accionable, etc.) [web:62][web:69][web:67][web:76].

Se aplica a las métricas clave propuestas en el informe de indicadores de ataques impulsados por Agentic IA:

- Unsafe Action Rate (UAR).
- Policy Adherence Rate (PAR).
- Privilege-Escalation Distance (PED).
- Out-of-Role Action Rate (OORAR).
- Retrieval Risk Score (RRS).
- Cost-Exploit Susceptibility (CES).
- Time-to-Contain (TTC).
- Alert Triage Automation Rate.
- Mean Time to Triage (MTTT).
- False Positive Reduction Rate.

2. Resumen de la metodología GQM

Según Basili y trabajos posteriores, GQM se estructura en tres niveles jerárquicos [web:63][web:72][web:75]:

1. **Goal (Objetivo):** Qué se desea lograr, en relación con el objeto de medición, desde una perspectiva concreta y en un entorno determinado.
2. **Question (Pregunta):** Cuestiones que ayudan a saber si se está cumpliendo el objetivo.
3. **Metric (Métrica):** Datos cuantitativos que responden a las preguntas y permiten evaluar el grado de cumplimiento del objetivo.

En ciberseguridad, GQM se recomienda para asegurar que las métricas nacen de objetivos estratégicos (por ejemplo, nacionales) y no simplemente de los datos disponibles [web:62][web:69].

3. Resumen de los criterios PRAGMATIC

El enfoque PRAGMATIC, aplicado a métricas de seguridad, propone evaluar cada métrica según nueve criterios [web:67][web:73][web:76]:

- **P – Predictiva:** ¿Anticipa resultados futuros o cambios en el riesgo?
- **R – Relevante:** ¿Está alineada con objetivos y decisiones clave?
- **A – Accionable:** ¿Sugiere acciones concretas cuando varía?

- G – Genuina: ¿Refleja la realidad sin manipulaciones ni artefactos?
- M – Significativa (Meaningful): ¿Es comprensible y útil para las partes interesadas?
- P – Precisa (Accurate): ¿Es suficientemente exacta y fiable para su uso?
- T – Oportuna (Timely): ¿Se puede obtener con la frecuencia necesaria?
- I – Independiente: ¿No depende excesivamente de una sola fuente o proveedor?
- C – Rentable (Cost-effective): ¿Aporta más valor que el coste de medirla?

En la práctica, cada criterio se puntúa, por ejemplo, en una escala de 1 (bajo) a 5 (alto), y se obtiene un **score PRAGMATIC** por métrica [web:76].

4. Cadena de trazabilidad: de objetivos nacionales a datos técnicos

El marco propone construir la trazabilidad de la siguiente forma:

4. Objetivos nacionales / sectoriales

5.

Ejemplos: reducción del impacto económico de ciberataques, mejora del tiempo de respuesta ante incidentes, cumplimiento de RGPD y AI Act, resiliencia de infraestructuras críticas.

6.

Objetivos organizativos

7.

Derivan de los nacionales, adaptados al contexto de la empresa: proteger datos personales sensibles, reducir incidentes graves, aumentar la capacidad de contención automática, etc.

8.

Objetivos GQM específicos (Goal)

9.

Se expresan en términos de “analizar/ controlar/ mejorar” una característica concreta ligada a Agentes IA (seguridad del comportamiento del agente, eficacia de SOC, etc.).

10.

Preguntas (Question)

11.

Traducen el objetivo a cuestiones concretas que la dirección y los equipos operativos necesitan responder.

12.

Métricas (Metric)

13. Se definen de forma operativa (fórmula, fuente de datos, frecuencia, responsable).

14. Se evalúan con PRAGMATIC para priorizar cuáles merece la pena implantar.

Ejemplos: reducción del impacto económico de ciberataques, mejora del tiempo de respuesta ante incidentes, cumplimiento de RGPD y AI Act, resiliencia de infraestructuras críticas.

Objetivos organizativos

Derivan de los nacionales, adaptados al contexto de la empresa: proteger datos personales sensibles, reducir incidentes graves, aumentar la capacidad de contención automática, etc.

Objetivos GQM específicos (Goal)

Se expresan en términos de “analizar/ controlar/ mejorar” una característica concreta ligada a Agentic IA (seguridad del comportamiento del agente, eficacia de SOC, etc.).

Preguntas (Question)

Traducen el objetivo a cuestiones concretas que la dirección y los equipos operativos necesitan responder.

Métricas (Metric)

5. Esquema QQM para cada métrica de Agentic IA

En los archivos complementarios se ofrece el detalle, pero el esquema general es:

5.1. Ejemplo abreviado para Unsafe Action Rate (UAR)

- **Goal:** Controlar y reducir la frecuencia de acciones inseguras ejecutadas por agentes de IA en sistemas críticos, para disminuir el riesgo de incidentes y brechas.
- **Questions:**
- ¿Con qué frecuencia los agentes generan acciones contrarias a las políticas internas?
- ¿En qué contextos y flujos de trabajo se concentran esas acciones inseguras?
- ¿Las acciones inseguras se detectan y bloquean antes de impactar en producción?
- **Metric (UAR):**
- **Definición:** número de escenarios de prueba o ejecuciones en los que se observa al menos una acción insegura del agente / número total de escenarios o ejecuciones evaluadas, en un período dado.
- **Unidad:** porcentaje (%).
- **Frecuencia:** mensual / trimestral.
- **Fuentes:** logs del agente, resultados de red-teaming, bancos de pruebas.

5.2. Estructura replicable

Para cada indicador se sigue el mismo patrón:

15. Objetivo GQM alineado con metas nacionales/organizativas.
16. 3–6 preguntas de gestión y operación.
17. Definición técnica de la métrica (fórmula, fuentes, frecuencia, alcance).
18. Evaluación PRAGMATIC resumida.

6. Integración en el ciclo de gestión de riesgos

19. Definir objetivos nacionales/sectoriales relevantes (por ejemplo, del marco de ciberseguridad nacional, estrategias de IA confiable).
20. Traducirlos a objetivos GQM para la organización, separados por dominios: agentes defensivos, agentes de negocio, SOC, etc.
21. Diseñar las métricas Agentic IA mediante GQM, garantizando que cada métrica responde a al menos una pregunta relevante.
22. Filtrar y priorizar métricas con PRAGMATIC, descartando aquellas que no aporten suficiente valor o sean demasiado costosas de obtener.
23. Integrar métricas seleccionadas en paneles de control y procesos de decisión (comités de riesgos, reporting al regulador, etc.).
24. Revisar periódicamente la pertinencia de las métricas y sus puntuaciones PRAGMATIC, adaptándolas a la evolución tecnológica y regulatoria.

7. Beneficios esperados

- Trazabilidad clara desde objetivos nacionales y normativos hasta los logs técnicos de los agentes.
- Selección de métricas que no solo describen el pasado, sino que predicen y permiten actuar sobre el futuro.
- Una base común para dialogar entre reguladores, CISOs, responsables de negocio y equipos técnicos en torno a la Agentic IA.